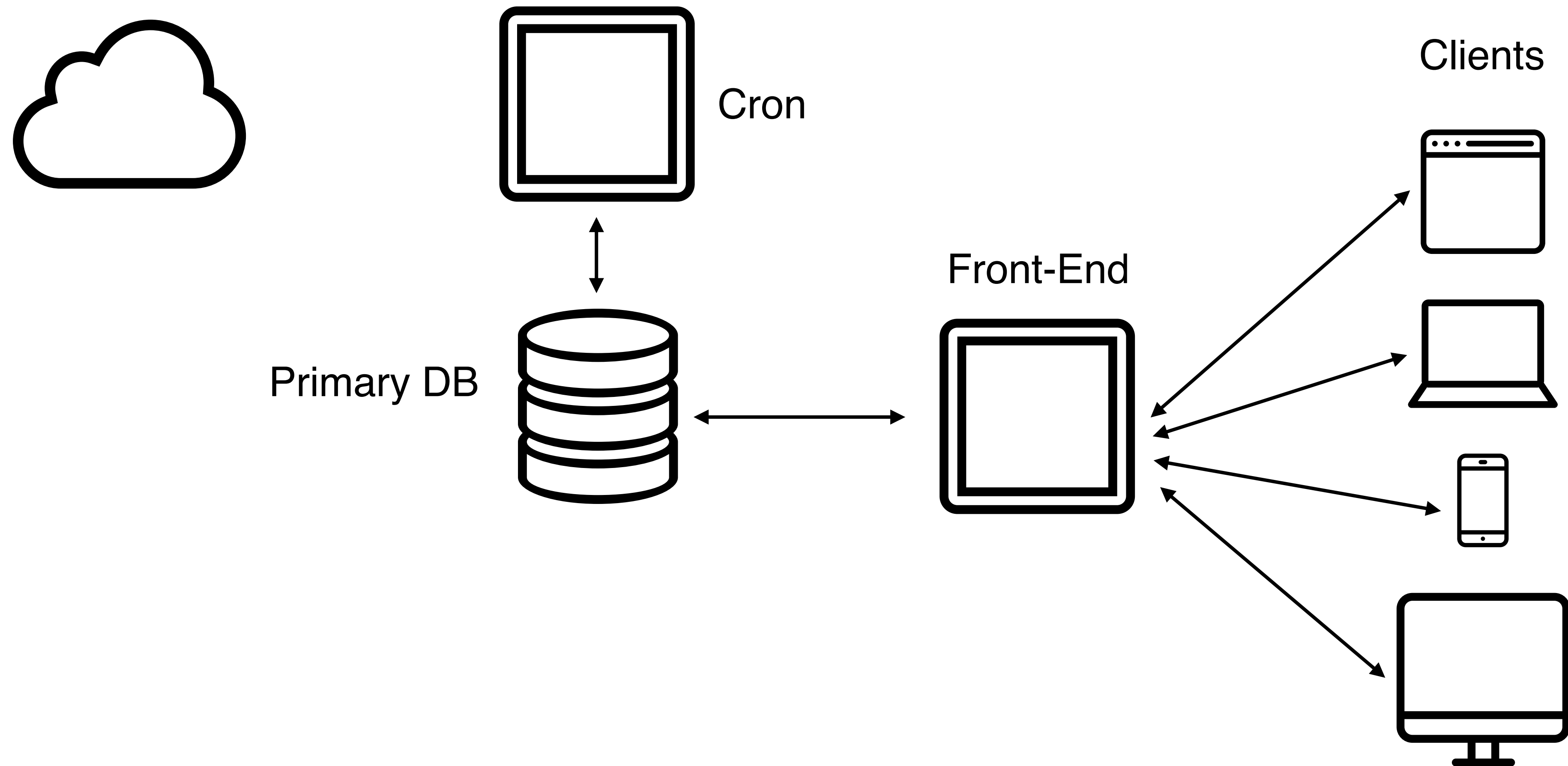


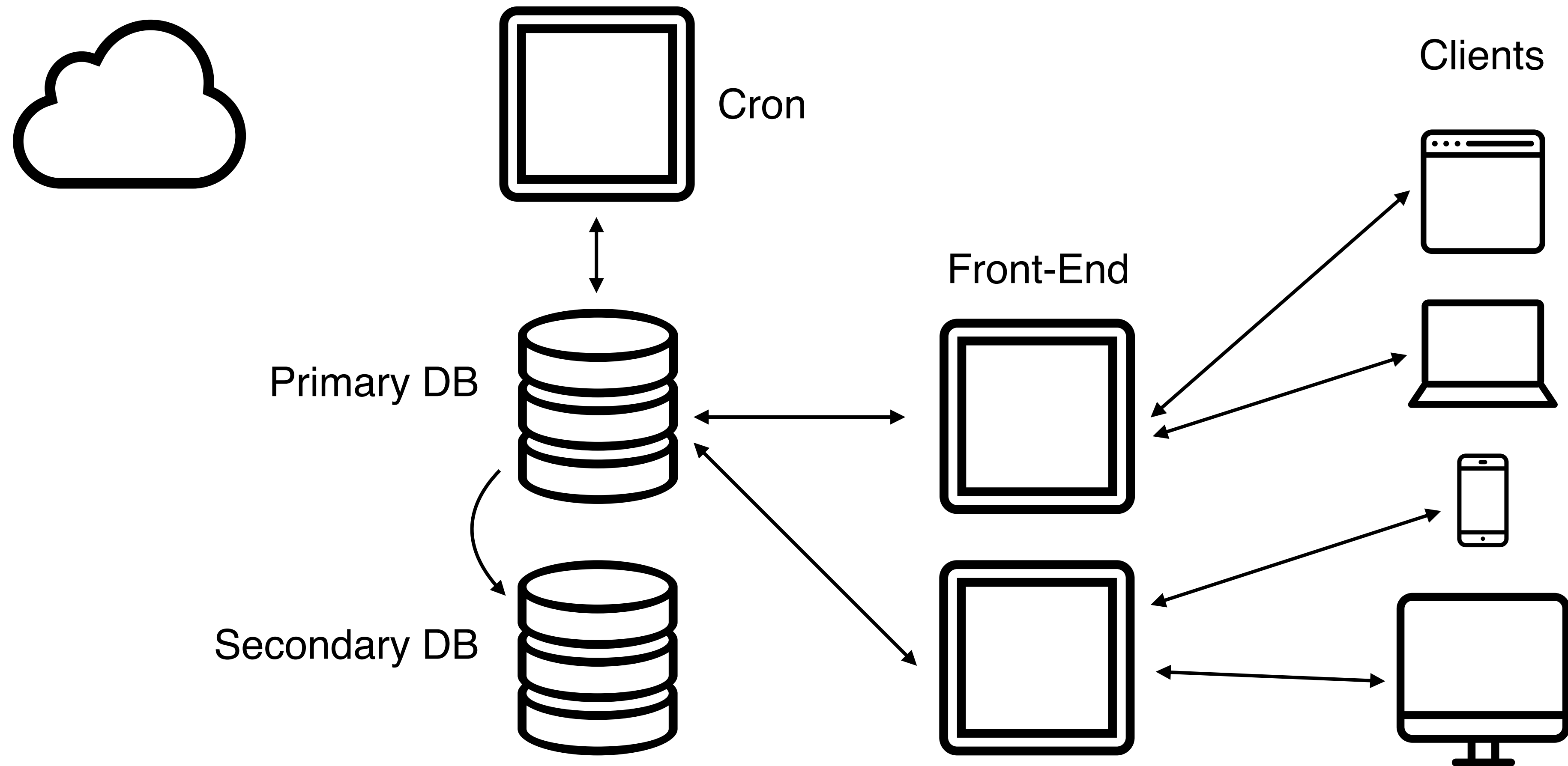


EVERYTHING IS TERRIBLE

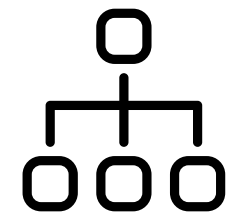
[FRED HÉBERT]

@mononcqc





COMMON ABSTRACTIONS



Memory access

Data Structures

Arrays, maps, dictionaries, sets, lists, trees, ...



Arbitrary references

Identifiers

Means to obtain the actual information we need



Bits and bytes

Numbers

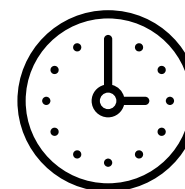
Additions, subtractions, not just logic gates with 1s and 0s



Packets and Streams

Networks

Packets, streams, IP addresses, routing, reliability



WTF?!

Time

Millenia worth of angry philosophers



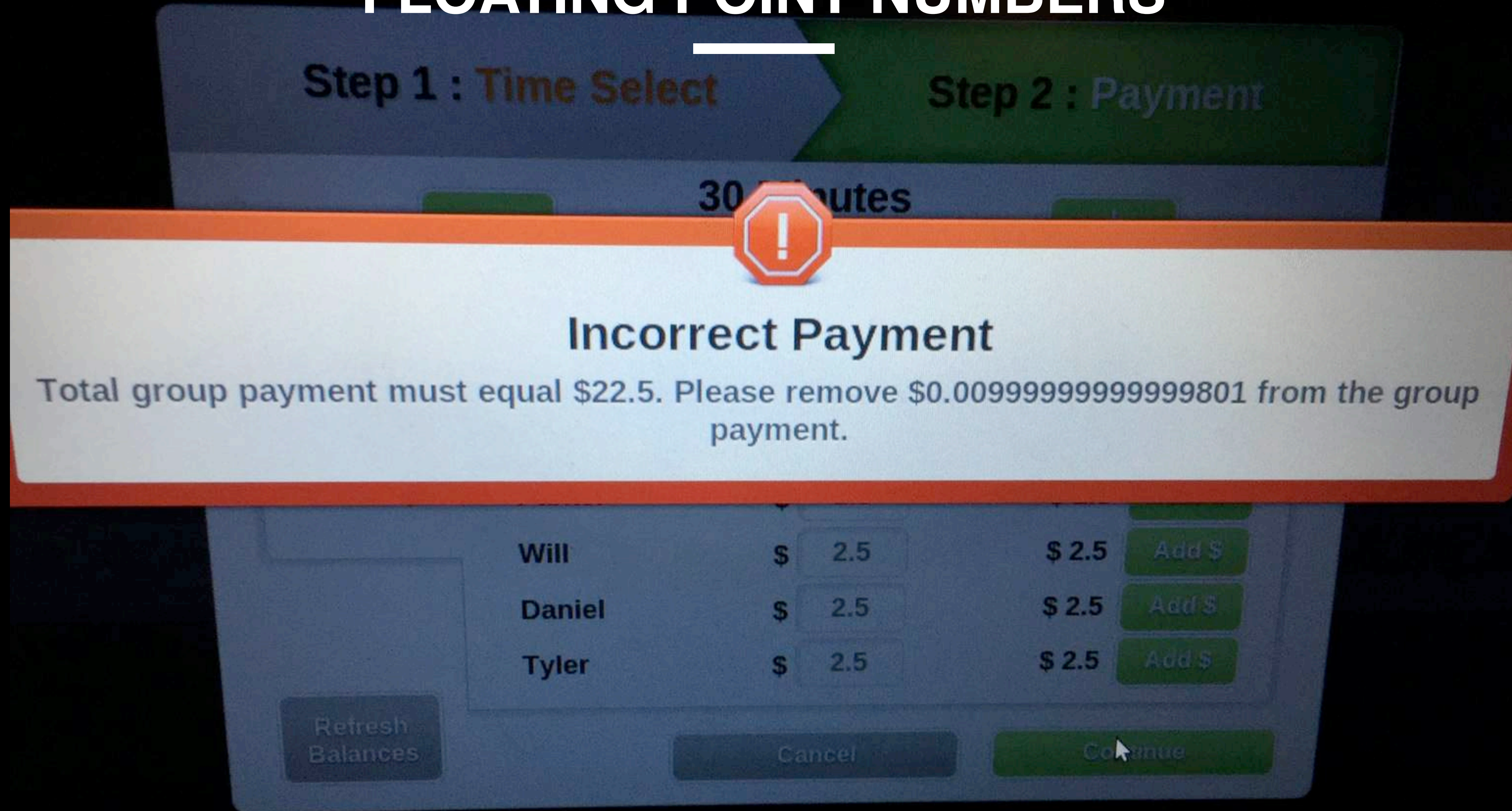
Languages

Strings and Text

“Everything is terrible”

numbers

FLOATING POINT NUMBERS



TYPES AND STRUCTURE

Not all numbers can be compared to any other number. Type usage can allow some protection as long as discipline is used when designing the program.



TYPES AND STRUCTURE

Not all numbers can be compared to any other number. Type usage can allow some protection as long as discipline is used when designing the program.

“Who is the king of the United States”

tap to edit

The answer is about 1.57 billion Chinese kings.

Input interpretation

convert United States total area to Chinese kings

Result

1.568×10^9 Chinese kings

Additional conversions

$9.631 \times 10^6 \text{ km}^2$ (square kilometers)

$9.631 \times 10^{12} \text{ m}^2$ (square meters)

3.719 million mi^2 (square miles)

$1.037 \times 10^{14} \text{ ft}^2$ (square feet)

Comparisons

$\approx 0.96 \times$ total area of Canada ($9.98467 \times 10^6 \text{ km}^2$)

$\approx 1.004 \times$ total area of China ($9.59696 \times 10^6 \text{ km}^2$)

Sequential IDs begone

WHAT'S IN A UUID

123e4567-e89b-12d3-a456-426655440000

00010010	00111110	01000101	01100111
11101000	10011011	00010010	11010011
10100100	01010110	01000010	01100110
01010101	01000100	00000000	00000000

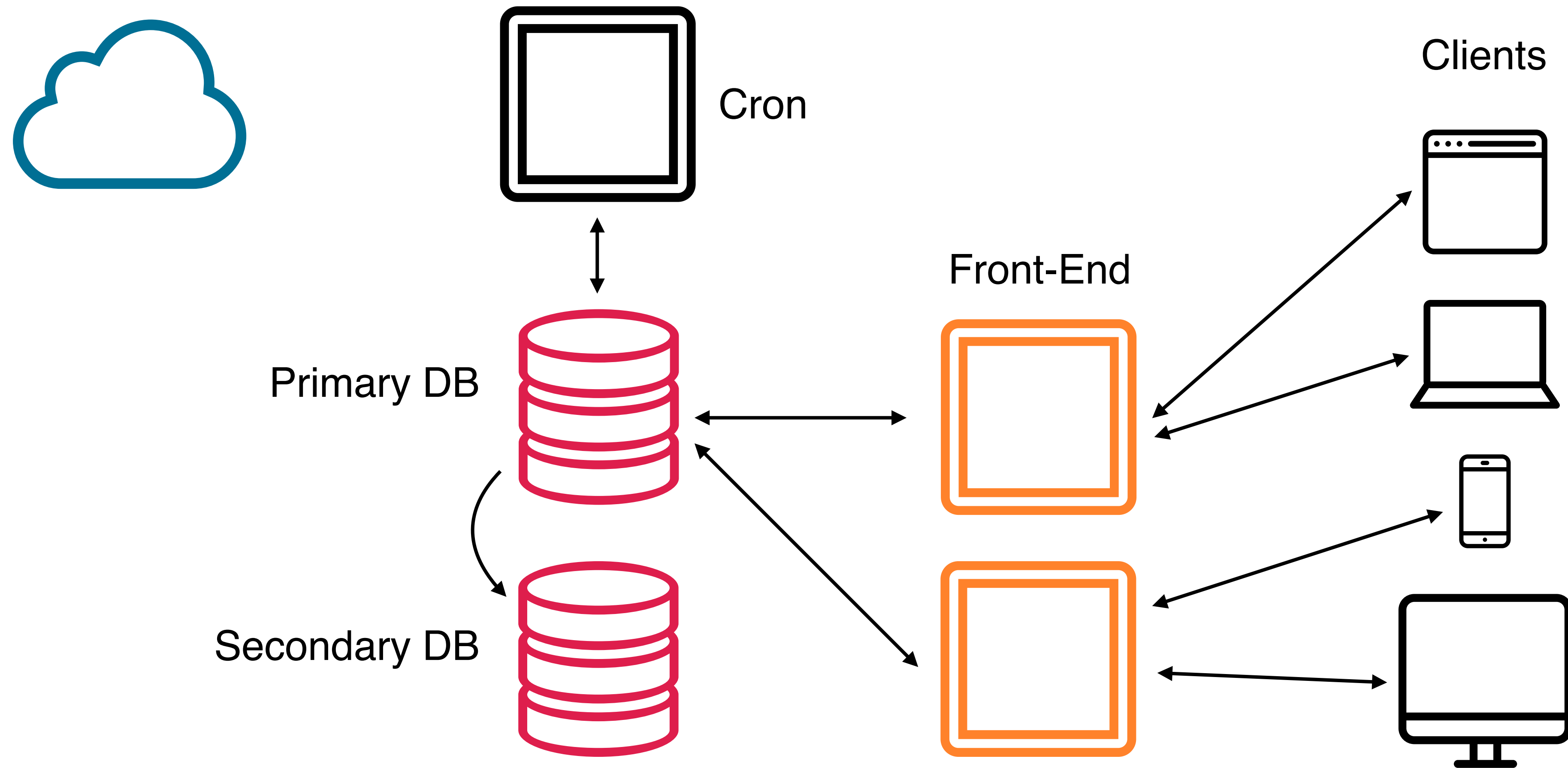
WHAT'S IN A UUID

“1 2 3 e 4 5 6 7 - e 8 9 b - 1 2 d 3 - a 4 5 6 - 4 2 6 6 5 5 d 4 0 0 f 0”

“1 2 3 E 4 5 6 7 - E 8 9 b - 1 2 D 3 - A 4 5 6 - 4 2 6 6 5 5 D 4 0 0 F 0”

“1 2 3 e 4 5 6 7 - e 8 9 b - 1 2 D 3 - a 4 5 6 - 4 2 6 6 5 5 D 4 0 0 f 0”

CONFLICTS AND UUIDs



PASSWORDS AND COMPARISONS

“N9qo8uLOickgx2ZMRZyeIjZAgcfl7p92ldGxad68”

==

“**N9qo**0bef4aebf1234a1e00fcrcfl7M62lmtxa482”

==

“**N9qo8uLOickgx2Z**34a1e00fcrcfl7M62lmtxa482”

PASSWORDS AND COMPARISONS

“N9qo8uLOickgx2ZMRZyeIjZAgcfl7p92ldGxad68”

XOR

“N9qo0bef4aebf1234a1e00fcrcfl7M62Imtxa482”

XOR

“N9qo8uLOickgx2Z34a1e00fcrcfl7M62Imtxa482”



Forgot Password

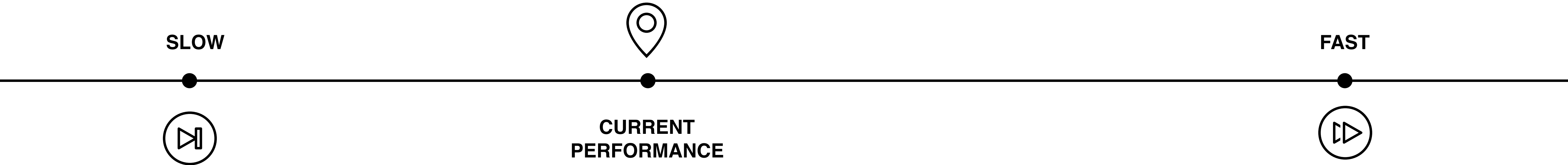
This password will also unlock your account.

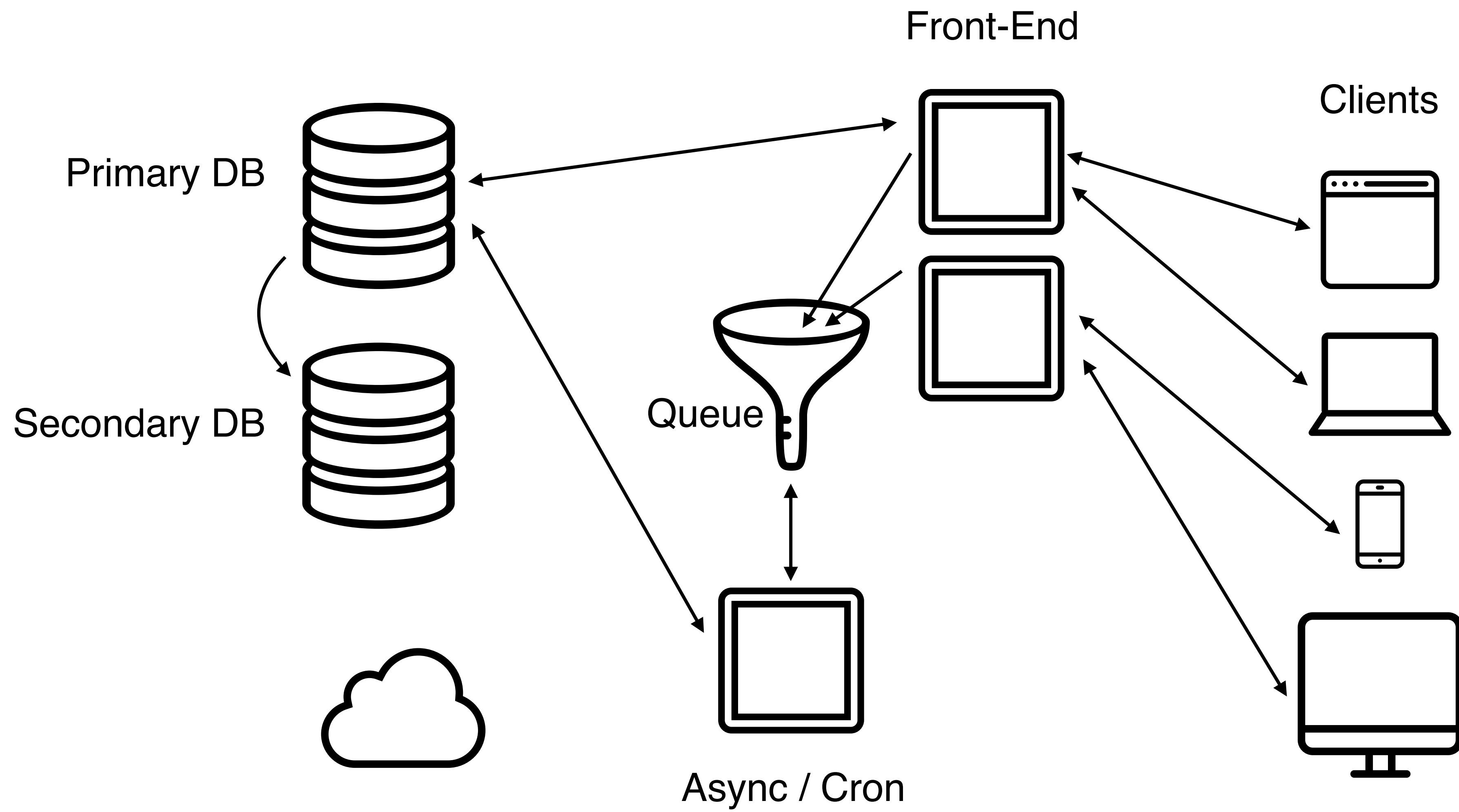
We will send you a temporary password via U.S. Mail to your mailing address.

Send Me a Temporary Password

Scaling

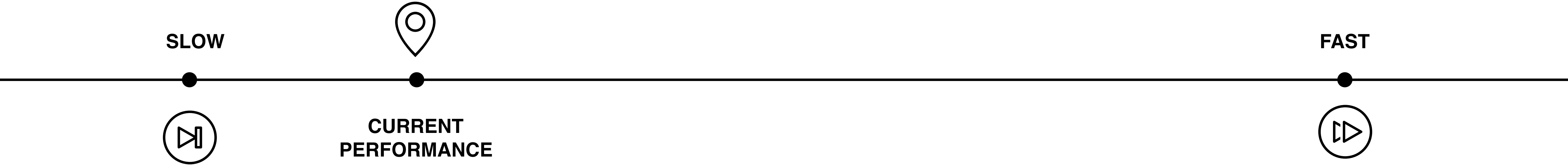
APPLICATION SPEED

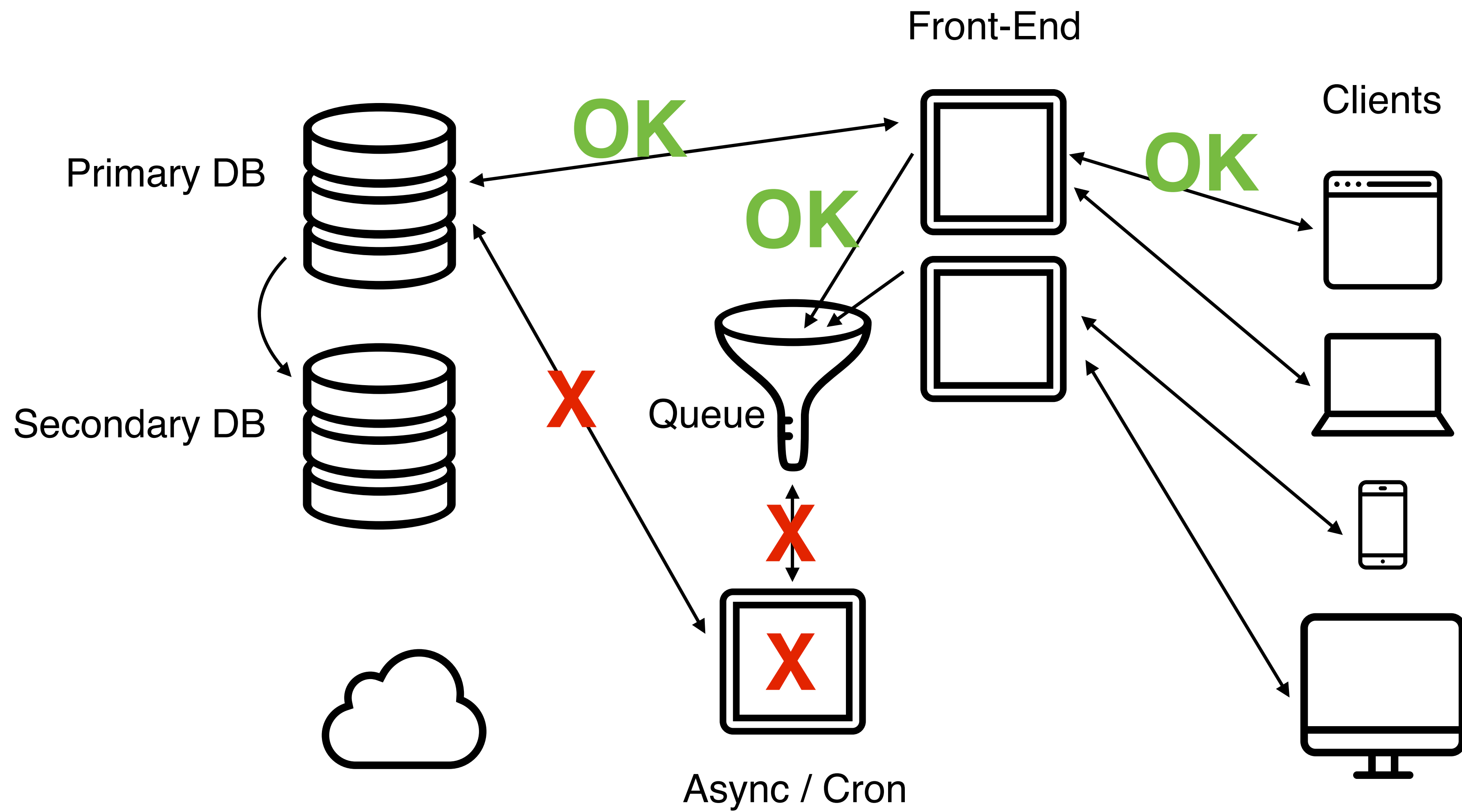




Scaling

APPLICATION SPEED





TOTALLY FREE
XX

Current balance
\$-93,026.73

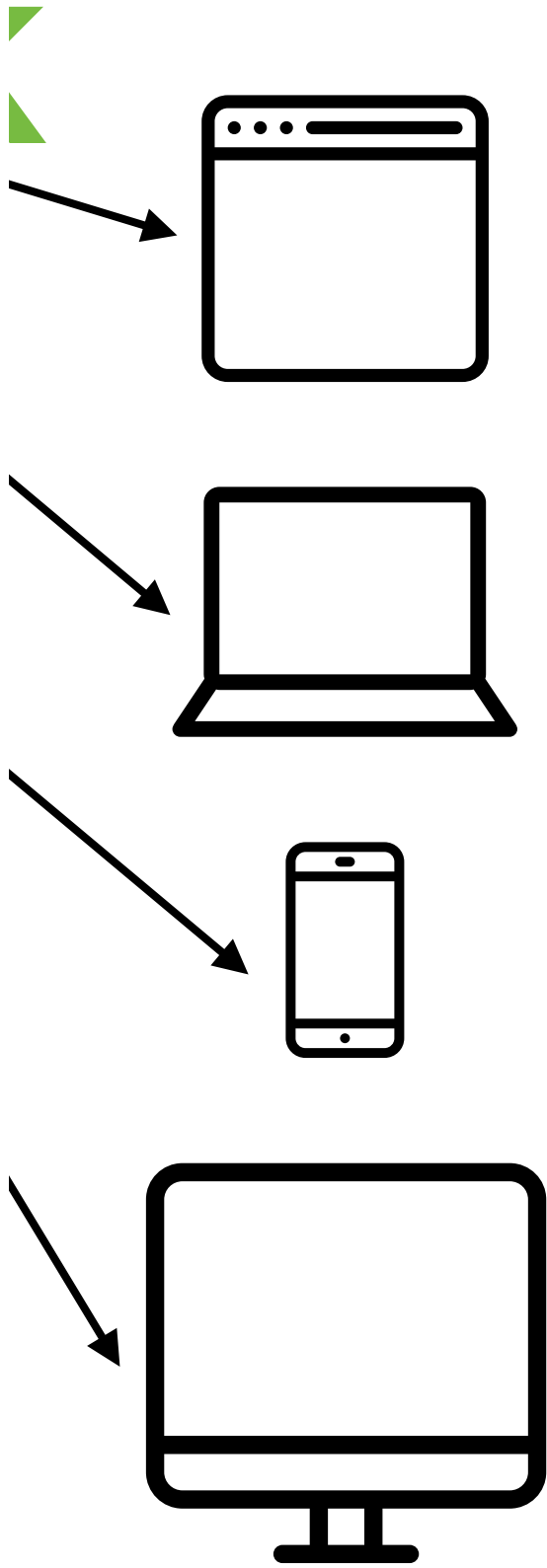
Recent

DB
Primaire

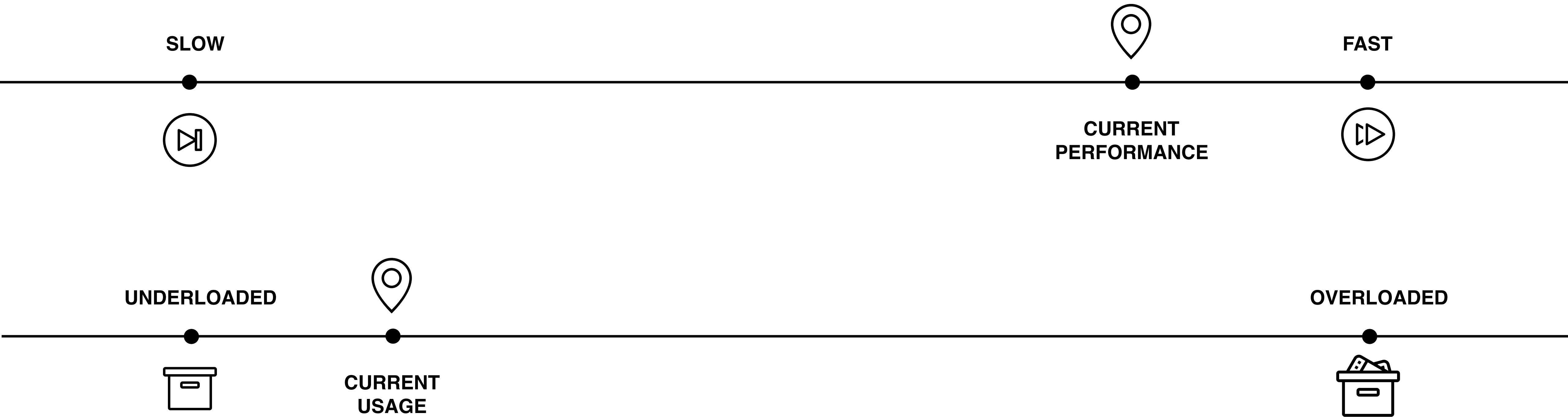
DB
Secondaire

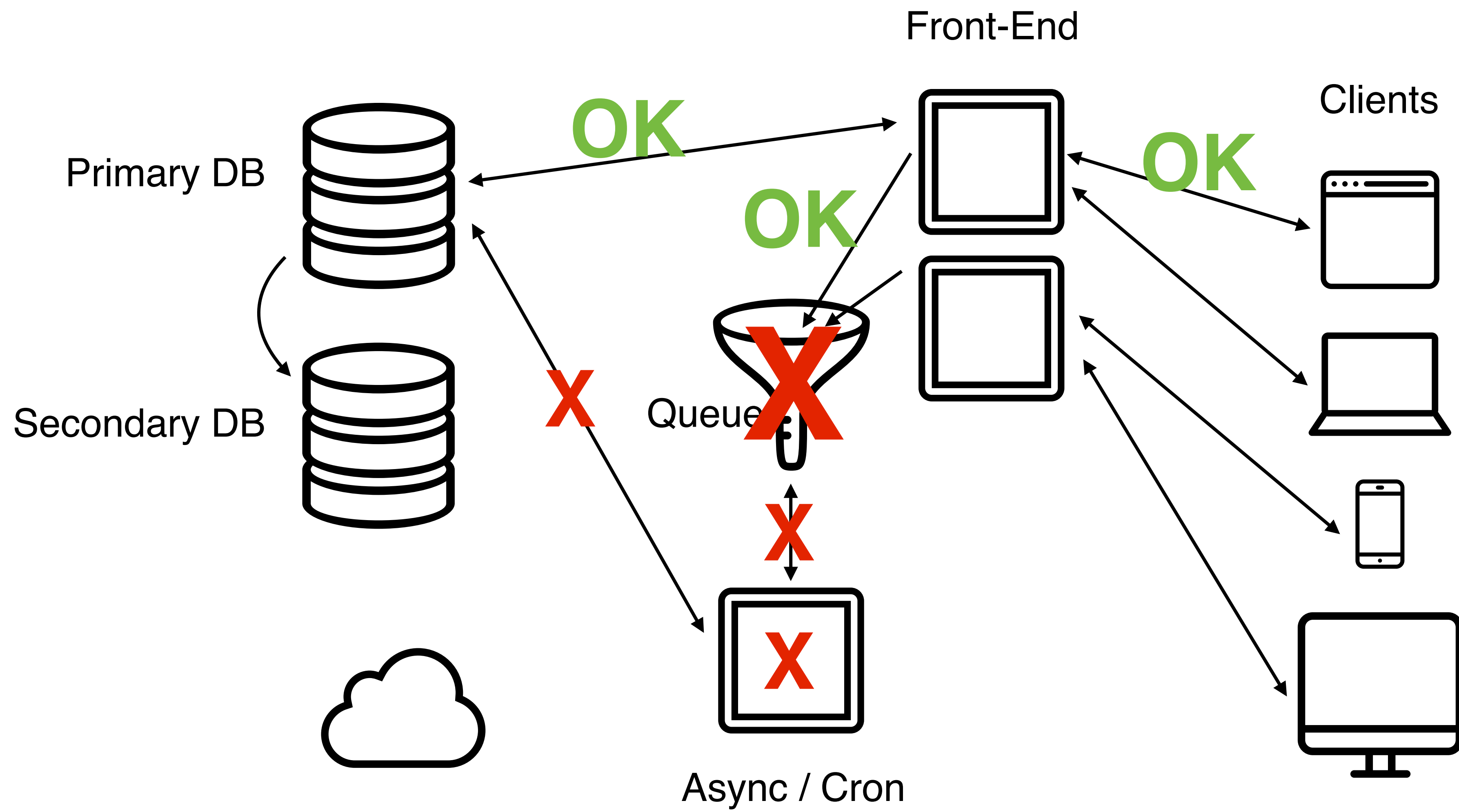
Date	Description	Amount
Jan 09, 2017	172417 PRE-AUTHORIZE.. STEAMGAMES.COM BELLEVUE WA 491207 700900005	-12.74
Jan 09, 2017	172417 PRE-AUTHORIZE.. STEAMGAMES.COM BELLEVUE WA 491207 700900005	-12.74
Jan 09, 2017	172417 PRE-AUTHORIZE.. STEAMGAMES.COM BELLEVUE WA 491207 700900005	-12.74
Jan 09, 2017	172417 PRE-AUTHORIZE.. STEAMGAMES.COM BELLEVUE WA 491207 700900005	-12.74
Jan 09, 2017	172417 PRE-AUTHORIZE.. STEAMGAMES.COM BELLEVUE WA 491207 700900005	-12.74
Jan 09, 2017	172417 PRE-AUTHORIZE.. STEAMGAMES.COM BELLEVUE WA 491207 700900005	-12.74
Jan 09, 2017	172417 PRE-AUTHORIZE.. STEAMGAMES.COM BELLEVUE WA 491207 700900005	-12.74
Jan 09, 2017	172417 PRE-AUTHORIZE.. STEAMGAMES.COM BELLEVUE WA 491207 700900005	-12.74
Jan 09, 2017	172417 PRE-AUTHORIZE.. STEAMGAMES.COM BELLEVUE WA 491207 700900005	-12.74
Jan 09, 2017	172417 PRE-AUTHORIZE.. STEAMGAMES.COM BELLEVUE WA 491207 700900005	-12.74

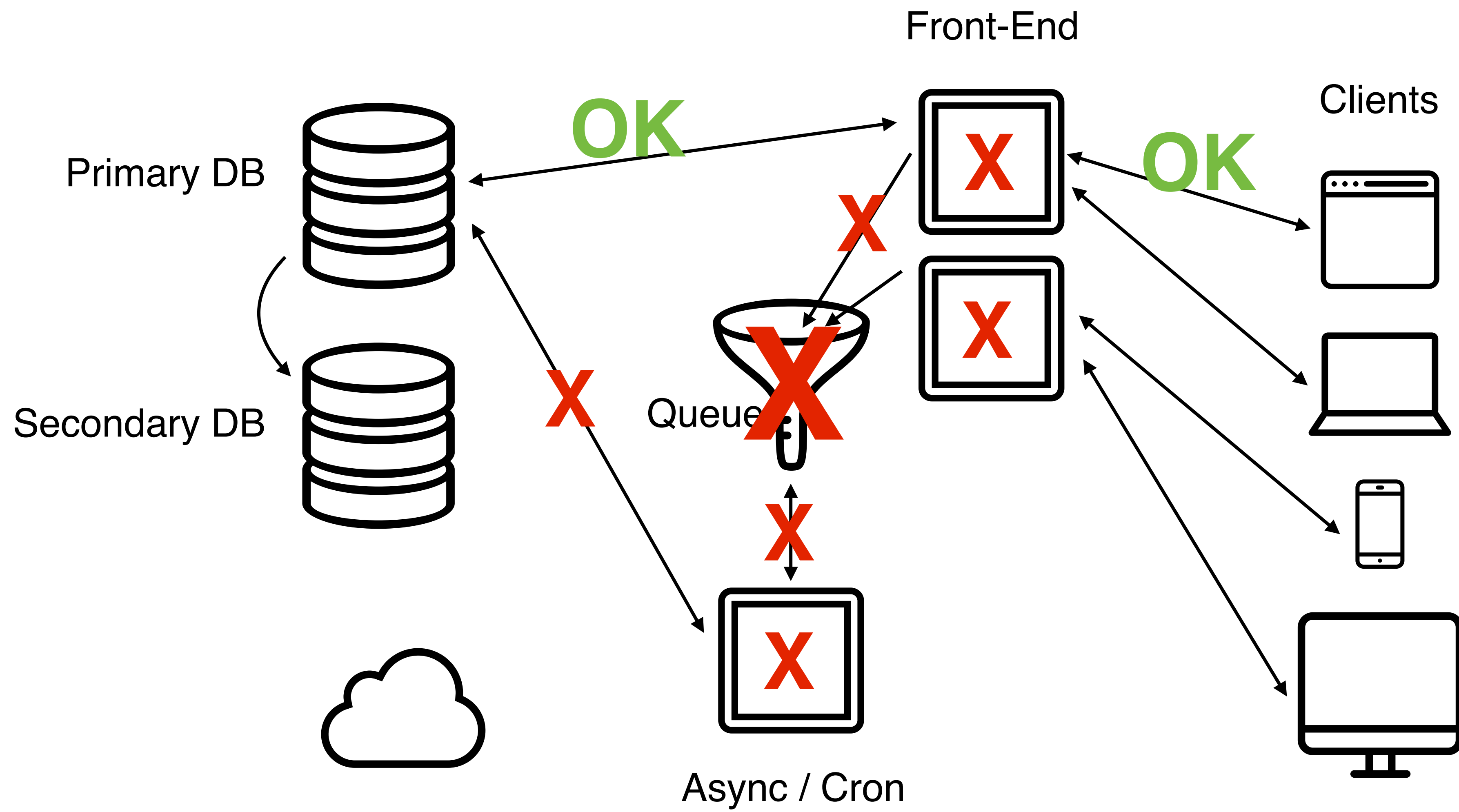
Clients

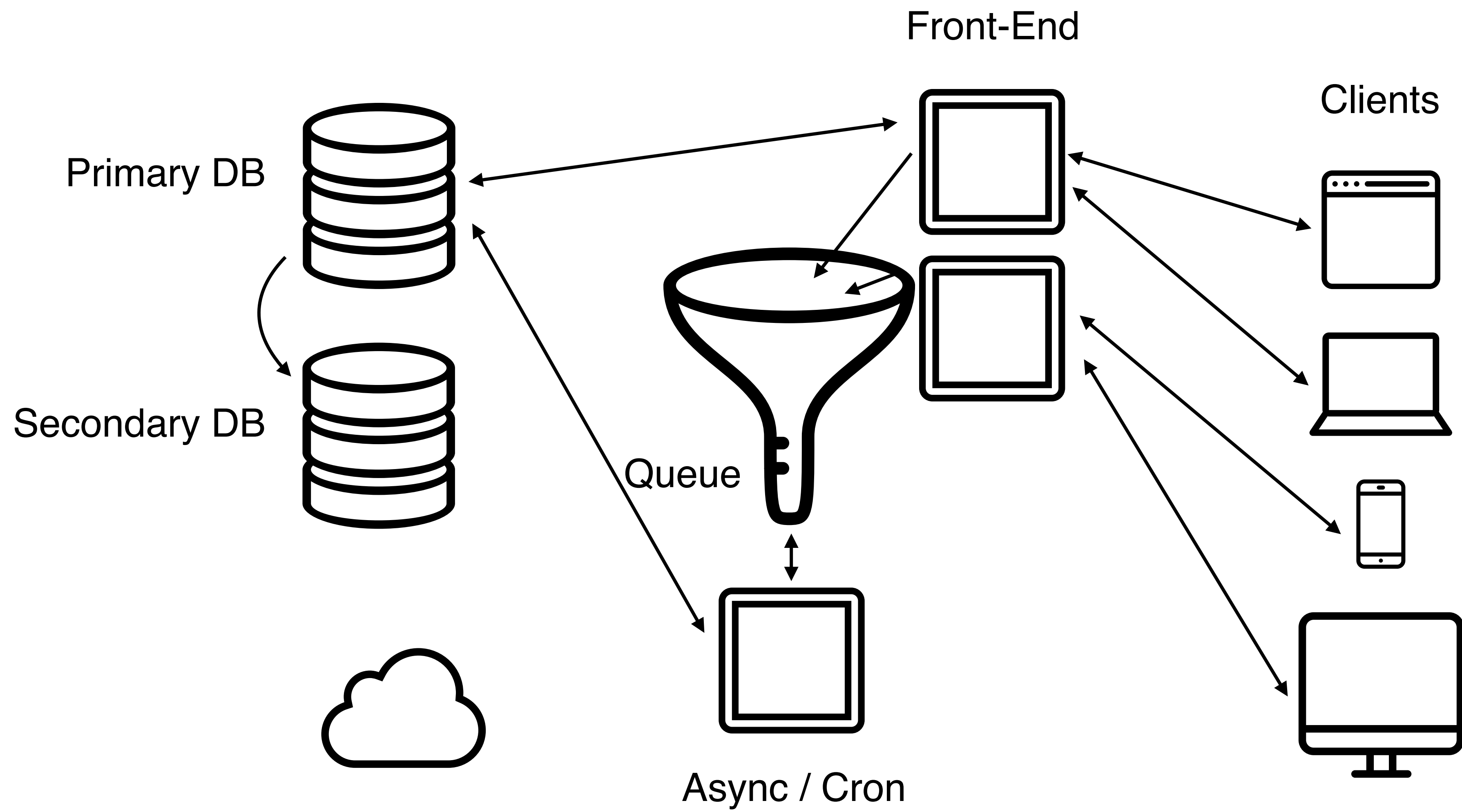


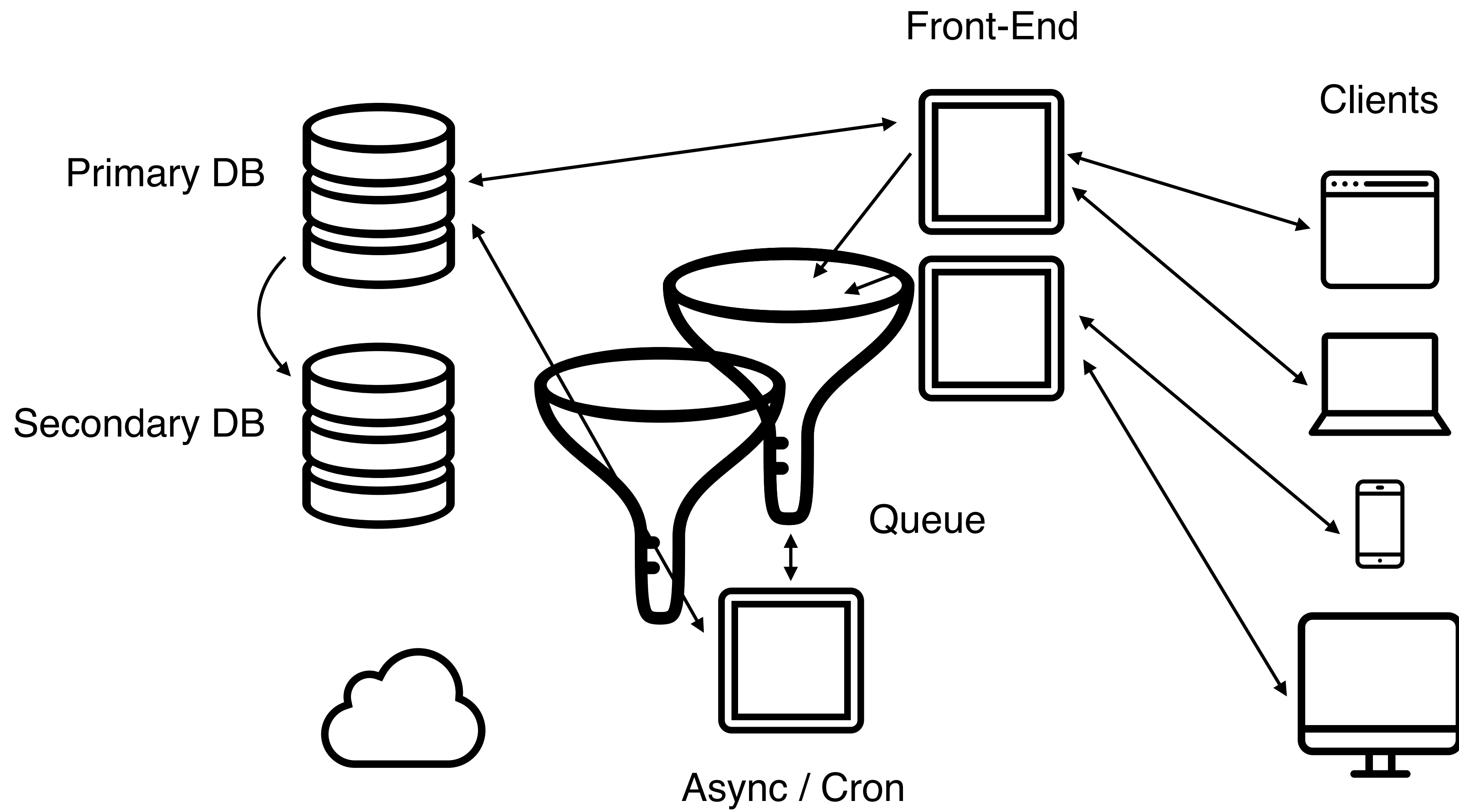
APPLICATION SPEED

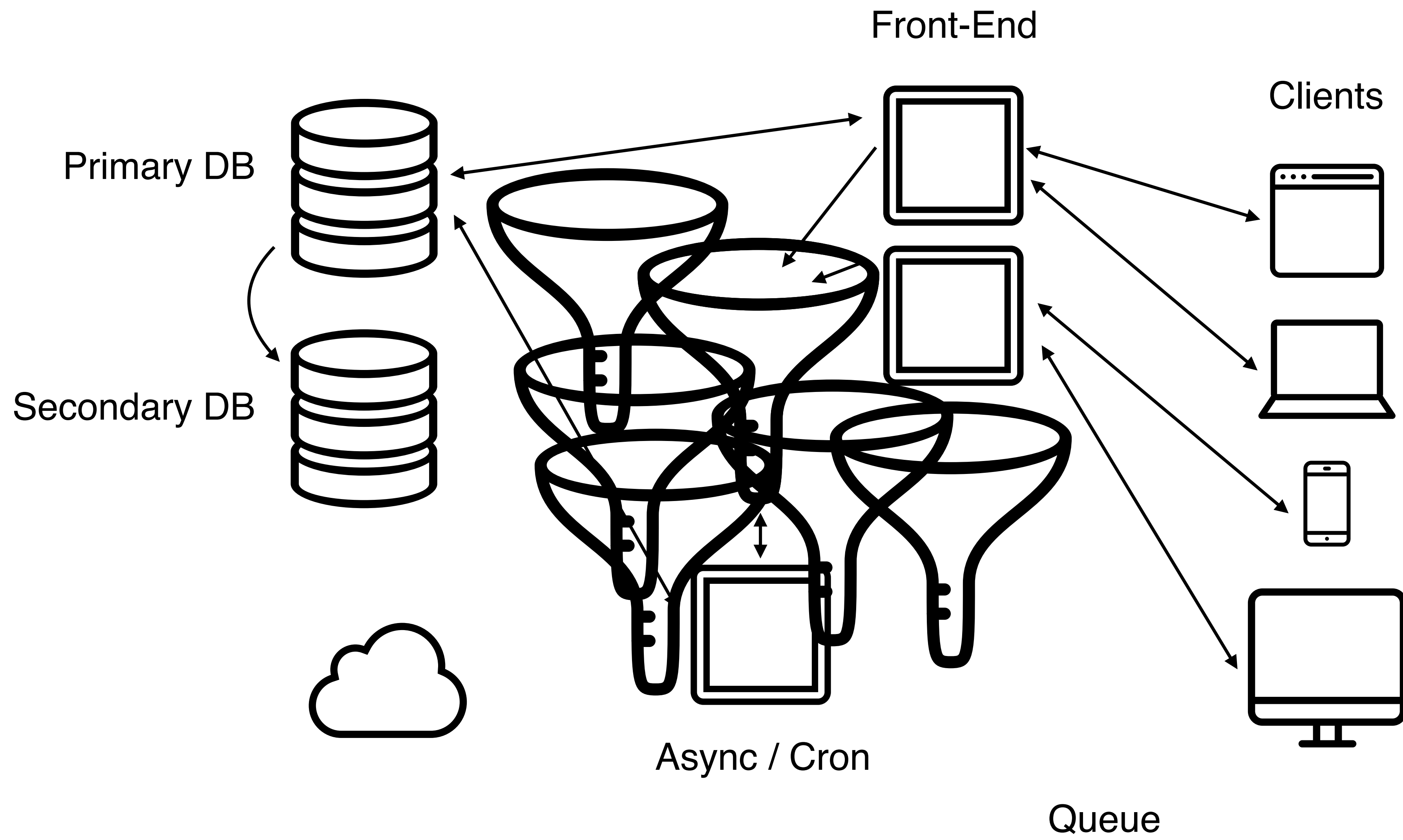


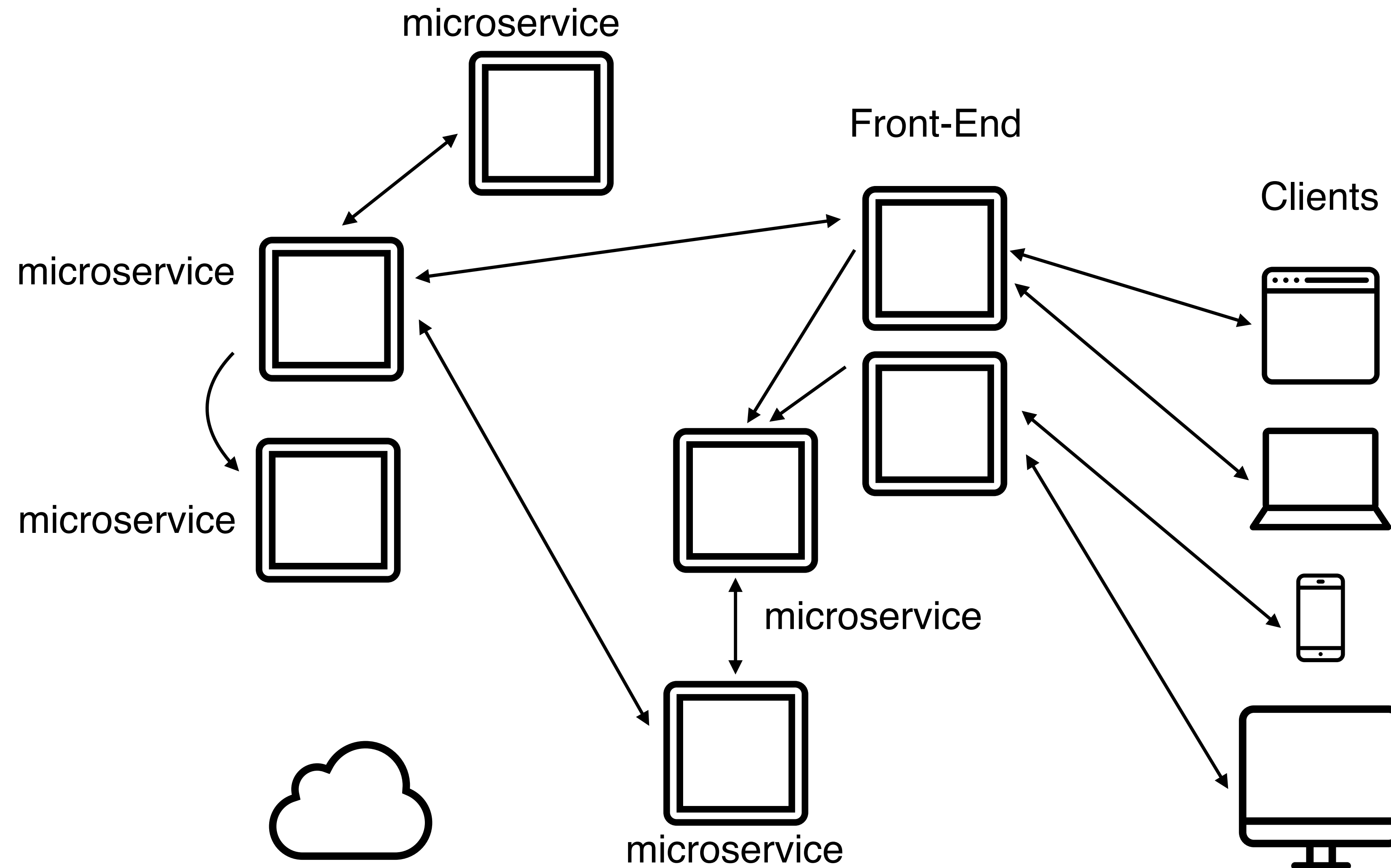


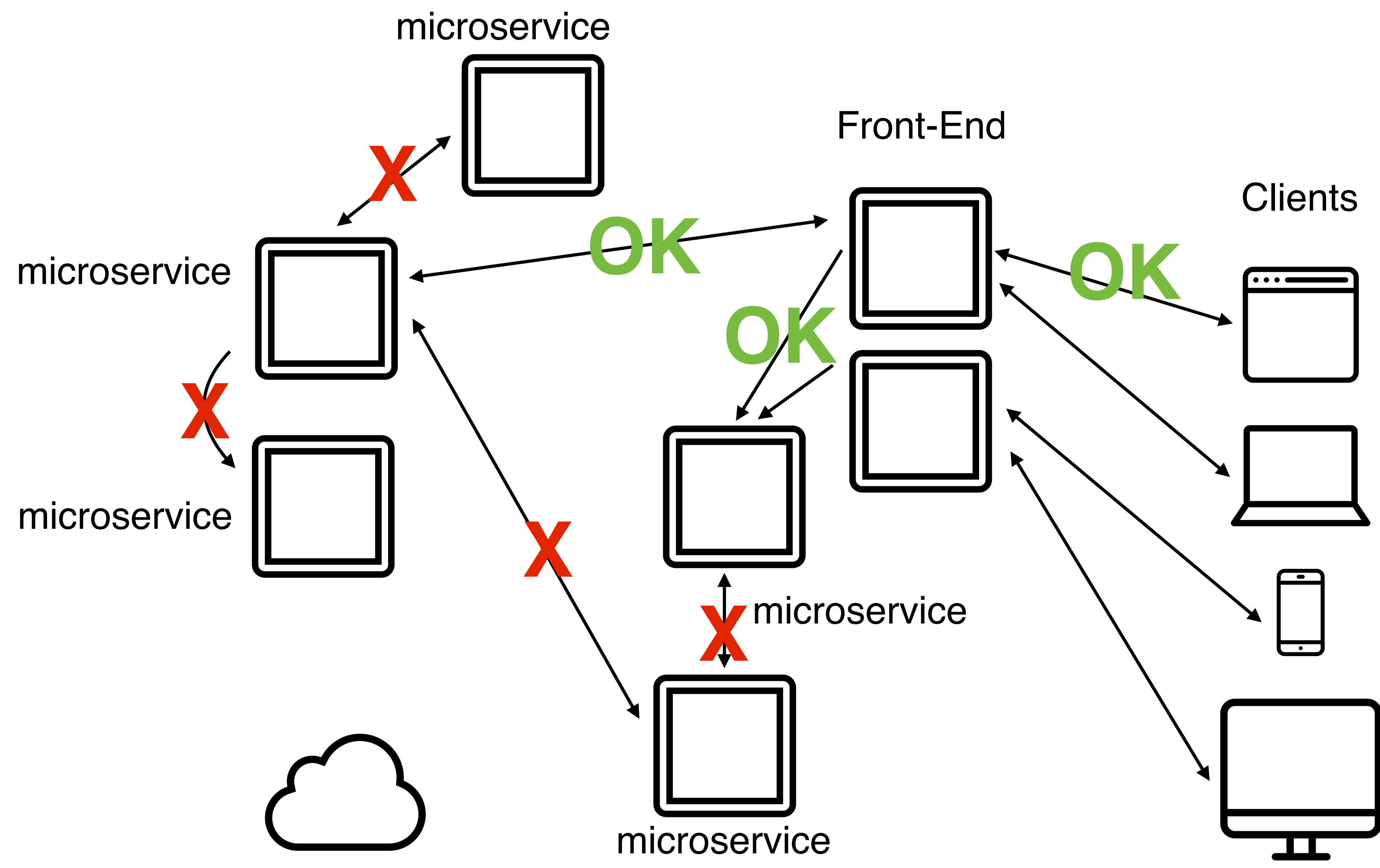












JSON Parsing Tests, Pruned

Appendix to: seriot.ch [Parsing JSON is a Minefield](http://www.seriot.ch/parsing_json.php) http://www.seriot.ch/parsing_json.php

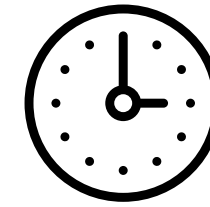
2016-11-05 00:04:08

[illegible]

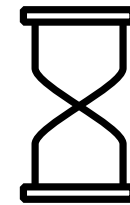
i_number_huge_exp.json		[0.4e006699999999999999999999999999 (...)]
i_number_neg_int_huge_exp.json		[-1e+9999]
i_number_pos_double_huge_exp.json		[1.5e+9999]
i_number_real_neg_overflow.json		[-123123e100000]
i_number_too_big_neg_int.json		[-123123123123123123123123123123]
i_number_double_huge_neg_exp.json		[123.456e-789]
i_number_real_underflow.json		[123e-10000000]
n_number_-2..json		[-2.]
n_multidigit_number_then_00.json		12300 <=> 123
n_string_escape_x.json		["\x00"]
n_string_incomplete_surrogate_escape_invalid.json		["\uD800\uD800\x"]
n_number_0.3e+.json		[0.3e+]
n_structure_whitespace_formfeed.json		[0C] <=> []
n_number_9.e+.json		[9.e+]
n_string_backslash_00.json		["\00"] <=> ["\""]
n_string_unescaped_ctrl_char.json		["a00a"] <=> ["aa"]
n_structure_null-byte-outside-string.json		[00] <=> []
n_string_unescaped_tab.json		["09"] <=> [" "]
n_string_unescaped_newline.json		["new0Aline"] <=> ["new line"]
n_array_extra_comma.json		[",]
n_object_pi_in_key_and_trailing_comma.json		{"B9":"0",} <=> {" ":"0",}
n_object_trailing_comma.json		{"id":0,
n_array_just_minus.json		[-]
n_string_invalid_utf8_after_escape.json		["\E5"] <=> ["\"]
n_string_escaped_ctrl_char_tab.json		["\09"] <=> [" \""]
n_object_trailing_comment.json		{ "a": "b" } /** /
n_array_comma_after_close.json		["],
n_string_with_trailing_garbage.json		" x
n_number_-01.json		[-01]
n_number_with_leading_zero.json		[012]
n_number_neg_real_without_int_part.json		[-.123]
n_structure_number_with_trailing_garbage.json		2@
n_array_extra_close.json		["x"]]
n_structure_close_unopened_array.json		]]
n_object_single_quote.json		{ 'a': 0 }
n_number_NaN.json		[NaN]
n_structure_capitalized_True.json		[True]
n_number_-1.0..json		[-1.0.]
n_structure_object_with_comment.json		{ "a": /*comment*/ "b" }
n_string_single_doublequote.json		" "
n_object_trailing_comment_slash_open.json		{ "a": "b" } //
n_object_trailing_comment_open.json		{ "a": "b" } /** //
n_array_spaces_vertical_tab_formfeed.json		["0Ba"\f] <=> ["a"\f]
n_string_single_string_no_double_quotes.json		abc
n_array_comma_and_number.json		[, 1]
n_array_star_inside.json		[*]
n_number_hex_1_digit.json		[0x1]
n_object_non_string_key.json		{ 1: 1 }
n_number_.2e-3.json		[.2e-3]
n_number_+1.json		[+1]
n_object_repeated_null_null.json		{ null:null, null:null }
n_object_double_colon.json		{ "x" :: "b" }
n_array_1_true_without_comma.json		[1 true]
n_object_missing_semicolon.json		{ "a" "b" }
n_number_minus_space_1.json		[- 1]
n_array_colon_instead_of_comma.json		[" ": 1]
n_number_U+FF11_fullwidth_digit_one.json		[EFBC91] <=> [1]
n_string_invalid_unicode_escape.json		["\uqqqqq"]
n_structure_ascii-unicode-identifier.json		aC3A5 <=> aa
n_structure_unicode-identifier.json		C3A5 <=> â
n_structure_lone-invalid-utf-8.json		E5 <=>
n_array_a_invalid_utf8.json		[aE5] <=> [a]
n_string_accentuated_char_no_quotes.json		[C3A9] <=> [é]
n_array_invalid_utf8.json		[FF] <=> []
n_string_1_surrogate_then_escape_u.json		["\uD800\u"]
n_array_inner_array_no_comma.json		[3[4]]
n_array_incomplete.json		["x"

—

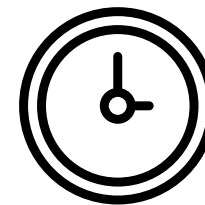
TIME VARIATIONS



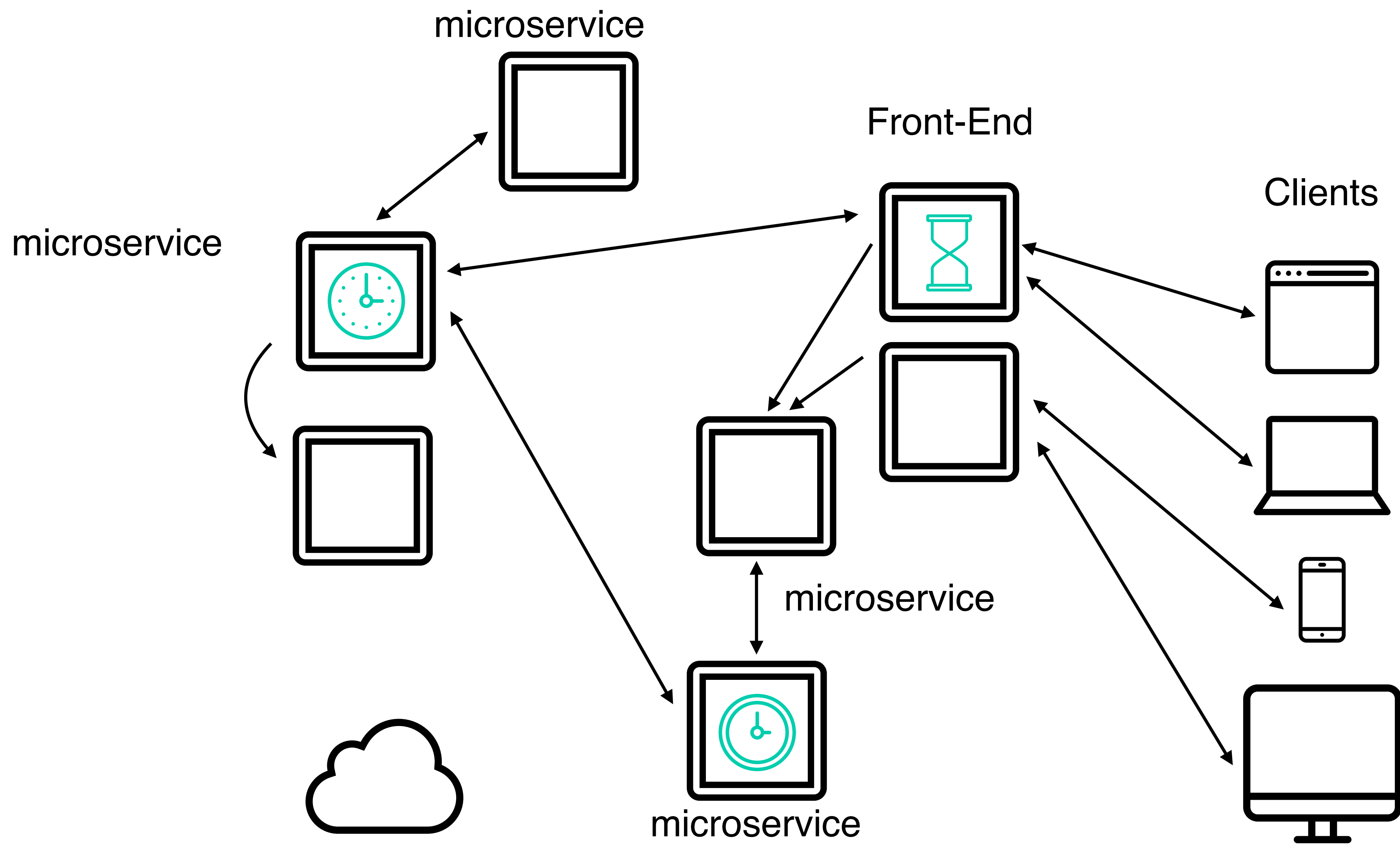
A

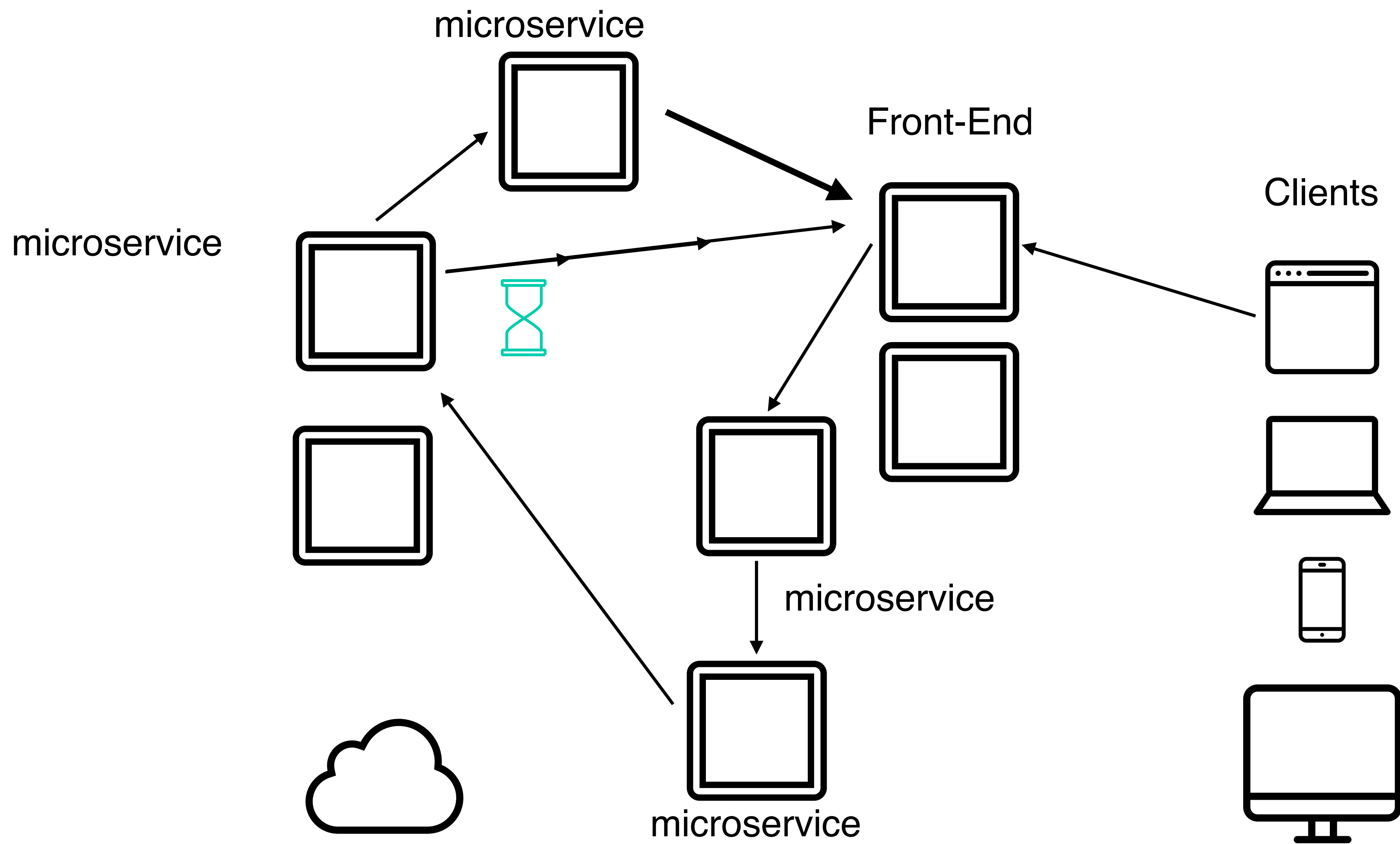


B



C







Stay up to date
Get shipment notifications



Time Zones

UTC+12:45/UTC+13:45

UTC+05:45

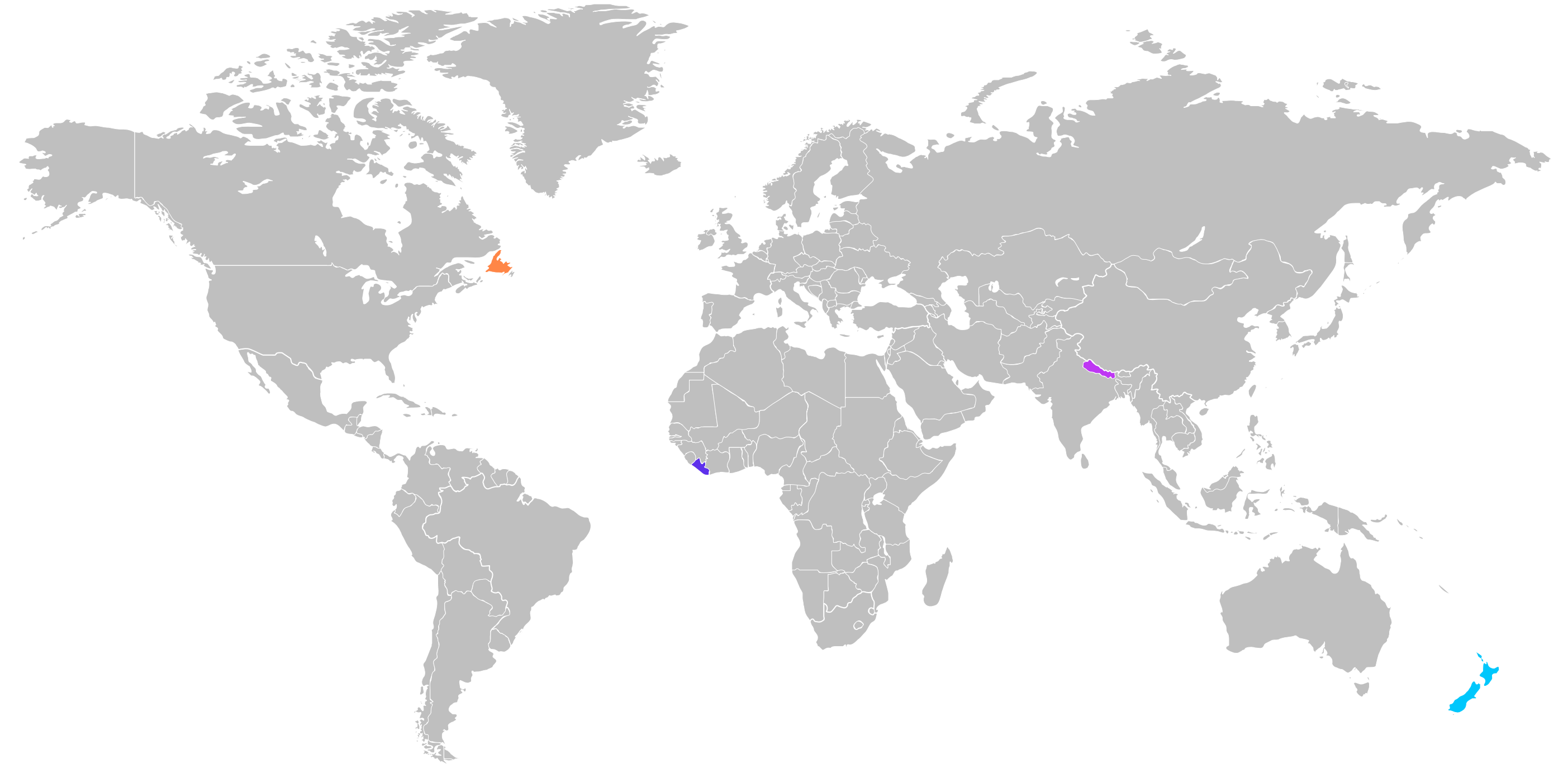
UTC-00:44 (avant 1972)

UTC-03:30

etc.

In 2011, Samoa islands went from UTC-11 to UTC+13, skipping December 31 for one year only. (4th of July happened twice in 1892).

In Brazil, DST is subject to a regional vote!



“Leap Seconds”



Calendars

Bengalis

Chinese / Gregorian

Ethiopian

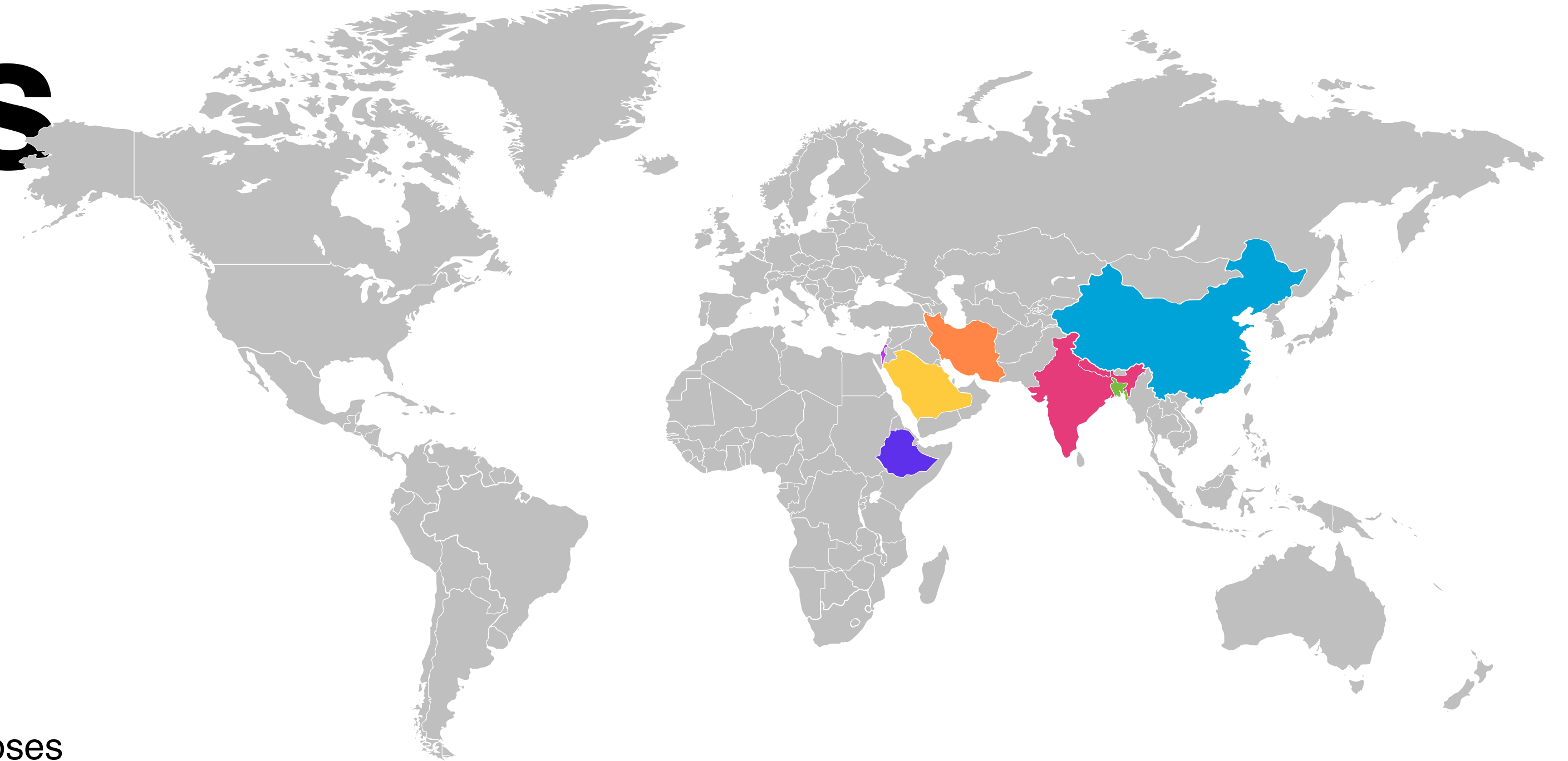
Hebrew / Gregorian

Hindu

Persian

Muslim

And > 20 other ones used for religious or ritualistic purposes



UNICODE NIGHTMARES

Top stories

THEHILL



Spicer: White House
â€”disgusted by CNNâ€™s
fake newsâ€™ | TheHill

⚡ AMP - 13 hours ago

UNICODE NIGHTMARES

impossible to distinguish ISO-8859-1 from utf8 through
observation

to configure: db, connection db, language, front-end, etc.

UNICODE NIGHTMARES

अनि॥𐑖

bytes:

UTF-8: 14, UTF-16: 12, UTF-32: 20

code unit:

UTF-8: 14, UTF-16: 6, UTF-32: 5

code points:

5 (combining character)

grapheme clusters:

4

Cultural Insights

Languages we speak



59% · en_US



41% · en_US



30% · English



19% · Danish



12% · German

UNICODE NIGHTMARES

BigBird

bigbird

BIGBIRD

Ω

Ω

UNICODE NIGHTMARES

Source		NFD		NFC		NFKD		NFKC
fi FB01	:	fi FB01		fi FB01		f i 0066 0069		f i 0066 0069
2 ⁵ 0032 2075	:	2 5 0032 2075		2 5 0032 2075		2 5 0032 0035		2 5 0032 0035
fi 1E9B 0323	:	f ̇ ̇ 017F 0323 0307		fi 1E9B 0323		s ̇ ̇ 0073 0323 0307		š 1E69

SSL/TLS

The Most Dangerous Code in the World: Validating SSL Certificates in Non-Browser Software

Martin Georgiev
The University of Texas
at Austin

Rishita Anubhai
Stanford University

Subodh Iyengar
Stanford University

Dan Boneh
Stanford University

Suman Jana
The University of Texas
at Austin

Vitaly Shmatikov
The University of Texas
at Austin

In summary, SSL connections established by any of the above programs are insecure against a man-in-the-middle attack. All vulnerabilities have been empirically confirmed.

SSL/TLS

The Most Dangerous Code in the World: Validating SSL Certificates in Non-Browser Software

Some certificate validation errors are signaled through the return values of `SSL_connect`, while for other errors `SSL_connect` returns OK but sets internal “verify result” flags. Applications must call `SSL_get_verify_result` function to check if any such errors occurred. This approach is error-prone (see Section 7.6).

SSL/TLS

The Most Dangerous Code in the World: Validating SSL Certificates in Non-Browser Software

The certificate validation function in GnuTLS, `gnutls_certificate_verify_peers2`, has similarly atrocious error reporting. It takes a reference to `tls_status` as an argument and sets it to an appropriate error code if validation fails. For some errors (e.g., insufficient credentials or no certificate found), it returns a negative value; for others (e.g., self-signed certificate), it sets the error code but returns zero.

SSL/TLS

The Most Dangerous Code in the World: Validating SSL Certificates in Non-Browser Software

For example, Amazon's Flexible Payments Service PHP library attempts to enable hostname verification by setting cURL's `CURLOPT_SSL_VERIFYHOST` parameter to `true`. Unfortunately, the correct, default value of this parameter is 2; setting it to `true` silently changes it to 1 and disables certificate validation.



CLASS BREAKS

ONE BUG TO RUIN IT ALL

So everything truly is terrible

“The 's' in IoT stands for security”

ANDY GREENBERG SECURITY 07.21.15 8:00 AM

HACKERS REMOTELY KILL A JEEP ON THE HIGHWAY—WITH ME IN IT



Fridge caught sending spam emails in botnet attack

In the first documented attack of its kind, the Internet of Things has been used as part of an attack that sent out over 750,000 spam emails.



Mirai botnet attack hits thousands of home routers, throwing users offline

Germany's federal security office confirmed that almost a million customers in the country were affected by internet outages as a result of the attack.



CLASS BREAKS

ONE BUG TO RUIN IT ALL

So everything truly is terrible

@mononcqc